

[Anterior](#) [Índice](#) [Próxima](#)

1. Introdução

Ao mesmo tempo em que ocorreu um enorme avanço tecnológico nas comunicações em rede, possibilitando o compartilhamento de informações a nível mundial, a segurança dessas redes e informações tornou-se crítica. Sendo o meio físico compartilhado, a probabilidade de que pessoas não autorizadas consigam acesso a informações sigilosas através de métodos ilícitos é grande. Desse modo, o uso de especialistas em segurança, aliados a poderosas ferramentas que o auxiliem, tornou-se indispensável na gestão de sistemas computacionais modernos.

Uma dessas ferramentas é o **sistema de detecção de intrusão**, que, analogamente a um sistema do mesmo nome empregado na segurança domiciliar, é composto por **sensores** capazes de disparar um alarme caso algum evento determinado ou não esperado venha a acontecer.

Esse trabalho apresenta uma introdução a sistemas de detecção de intrusão, seus diferentes tipos baseados aonde é empregada a detecção, como são feitas as análises desses sistemas e ainda apresenta conceitos básicos sobre potes de mel.

1.1 Motivação

A medida que as tecnologias de rede vêm sofrendo um avanço enorme promovendo o compartilhamento de dados, sobretudo na Internet, é necessário encontrar algum meio de proteger informações de usuários não autorizados a obtê-las. A cada dia, é mais fácil obter ferramentas automatizadas ou o código-fonte de explorações de falhas de sistemas prontos que promovem acesso a servidores de redes, comprometendo sua segurança. Hoje em dia, não é mais necessário ter conhecimentos avançados em um determinado sistema operacional ou protocolo para explorar suas vulnerabilidades.

Existem diversas ferramentas que, juntas, contribuem significativamente para a melhoria da segurança de uma rede. Por exemplo, a criptografia estabelece um nível de proteção para dados, estejam eles em trânsito ou armazenados em disco. Um outro exemplo seria o uso de *firewalls*, que estabelecem uma lógica na entrada e saída da rede dizendo que somente pacotes com determinadas características podem atravessá-lo. É importante frisar que o uso de um SDI idealmente deve ser usado em conjunto com outras ferramentas para fortalecer a segurança do ambiente como um todo.

O principal objetivo para se usar um sistema de detecção de intrusão é para possuir o conhecimento de que está em andamento ou ocorreu uma tentativa de invasão e de que possivelmente houve algum comprometimento de algum servidor ou estação. Essa informação é crucial quando se quer proteger a integridade, privacidade e autenticidade de dados em uma rede, que é o ponto principal para se usar qualquer tipo de ferramentas de segurança. Muitas vezes, mesmo depois de um ataque, é importante fazer uma análise dos dados obtidos para saber a origem do atacante, até onde ele conseguiu penetrar e ainda recolher informações para prevenir que outros tipos de ataque sejam efetivados.

1.2 Visão Geral

Detecção de intrusão é uma tentativa de monitorar estações ou fluxos de rede com o intuito de descobrir ações de intrusos. Mais especificamente, um SDI tenta detectar ataques ou usos impróprios e alerta o responsável pela rede do acontecimento. O funcionamento é análogo ao de um sistema de detecção de ladrões, usado em casas

para se proteger de eventuais incidentes. O sistema domiciliar inicialmente precisa ser configurado e ter especificado o que monitorar (janelas, portas, movimento) e para quem alertar ou chamar em caso de uma invasão (polícia, donos da casa). No sistema computacional, também precisamos determinar se queremos monitorar fluxos de rede, processos internos de uma estação ou servidor, ou ainda um sistema de arquivos, por exemplo. E devemos deixar claro para quem enviar os alarmes ou relatórios e como estes devem ser enviados, tendo como alternativas o e-mail, pager, ou ainda um pacote SNMP.

Teoricamente, esse tipo de sistema seria somente passivo, observando pacotes na rede ou processos em uma estação de trabalho e alertando os responsáveis. Porém, alguns sistemas possuem a habilidade de reagir às invasões, deixando de ser um sistema exclusivamente de detecção e pode ser definido como um sistema de reação a intrusão. Exemplos de reação podem ser um fechamento de conexão, um bloqueio no *firewall*, execução de algum arquivo, ou ainda a desabilitação de uma conta.

1.3 Histórico

O conceito de detecção de intrusão foi introduzido por James Anderson, com o artigo "*Computer Security Threat Monitoring and Surveillance*" [1], no início de 1980. Seu artigo, escrito para uma organização governamental, definiu o conceito de que trilhas de auditoria podiam conter informações vitais que podiam ser valiosas no rastreamento de usos impróprios do sistema e ainda no entendimento do comportamento do usuário. Com a publicação deste artigo, surgiu a idéia de detecção de usos impróprios e de eventos. O artigo de Anderson forneceu o fundamento para o projeto e desenvolvimento futuros de SDIs e foi responsável pelo início da detecção de intrusão baseada na estação ([seção 2.2](#)).

Em 1983, a [SRI Internacional](#), e mais especificamente Dr. Dorothy Denning, começou a trabalhar num novo projeto do governo com objetivo de desenvolver a detecção de intrusão. O objetivo do projeto era analisar trilhas de auditoria providas dos *mainframes* do governo e traçar o perfil dos usuários baseado nas suas atividades. Um ano mais tarde, Dr. Denning ajudou a desenvolver o primeiro modelo para detecção de intrusão, o Sistema Especialista em Detecção de Intrusão, ou *Intrusion Detection Expert System* (IDES), o qual contribui para o desenvolvimento da tecnologia de SDIs que viria logo em seguida.

Em 1984, a SRI também desenvolveu um meio de rastrear e analisar dados de auditoria contendo informações de autenticação de usuários da ARPANET, a rede que futuramente seria a Internet. Posteriormente, a SRI finalizou um contrato com a marinha americana com a realização do primeiro sistema de detecção de intrusão funcional, IDDES. Usando sua pesquisa e trabalho desenvolvidos na SRI, Dr. Denning publicou seu artigo "*An Intrusion Detection Model*" [2], o qual revelava informações necessárias para o desenvolvimento de sistemas de detecção de intrusão comerciais. Seu trabalho foi a base para muito dos trabalhos em SDIs que se seguiram.

Enquanto isso, existiam outros avanços significativos ocorrendo no [Laboratório Nacional Lawrence Livermore](#) operado pela Universidade da Califórnia. Em 1988, o projeto *Haystack* (palheiro, em inglês - nome dado ao projeto devido a procura por um uso indevido em uma grande quantidade de dados ser análoga a uma busca por uma agulha num palheiro) lançou uma outra versão para detecção de intrusão para a Força Aérea Americana. Este projeto produziu um SDI que analisava trilhas de auditoria comparando-as com padrões pré-definidos. A continuação desse sistema levou a construção de uma ferramenta chamada Sistema de Detecção de Intrusão Distribuído, ou *Distributed Intrusion Detection System* (DIDS), o qual contribuiu com a versão anterior através do monitoramento das máquinas clientes, além das servidoras originalmente monitoradas. Em 1989, os desenvolvedores do projeto *Haystack*

formaram uma companhia comercial, *Haystack Labs*, e lançaram a última versão da tecnologia, *Stalker*. Os avanços da *Haystack*, junto com o trabalho da SRI e Denning, avançaram muito o desenvolvimento de tecnologias de detecção de intrusão baseadas na estação.

Nos anos 90, Todd Heberlein, da Universidade da Califórnia de Davis, introduziu a idéia de detecção de intrusão de rede ([seção 2.1](#)). Em 1990, Heberlein foi o autor principal e desenvolvedor do Monitor da Segurança de Rede, ou *Network Security Monitor* (NSM), o primeiro sistema de detecção de intrusão de rede [3]. O NSM foi empregado nas maiores instalações governamentais, onde a análise do tráfego de rede fornecia quantidades enormes de informação. Esse novo conceito gerou mais interesse na área de detecção de intrusão e os investimentos nesse mercado cresceram significativamente. As contribuições de Heberlein se estenderam até o projeto DIDS, onde juntamente com o time da *Haystack*, ele introduziu a primeira idéia de detecção de intrusão híbrida ([seção 2.3](#)). O trabalho do projeto *Haystack* e a introdução do NSM revolucionaram a área de SDIs e os trouxeram para o mundo comercial.

O desenvolvimento comercial de tecnologias relacionadas à detecção de intrusão começaram no início dos anos 90. A companhia *Haystack Labs* foi a primeira vendedora comercial dessas ferramentas, com sua linha *Stalker* de SDIs baseados em estação. SAIC também estava desenvolvendo uma forma de detector de intrusos baseados em estação chamado Sistema de Detecção de Uso Impróprio do Computador, ou *Computer Misuse Detection System* (CMDS). Ao mesmo tempo, o Centro de Suporte Criptológico da Força Aérea Americana, ou *Air Force's Cryptologic Support Center*, desenvolveu o Sistema de Medidas de Segurança Automatizado, ou *Automated Security Measurement System* (ASIM), com o objetivo de monitorar todo o tráfego da rede da Força Aérea Americana. O ASIM fez progressos consideráveis nos problemas de escalabilidade e portabilidade que eram as principais falhas nos sistemas baseados em rede. Além disso, ele foi o primeiro sistema a incorporar uma solução tanto de software como de hardware em detecção de intrusão de rede. Ele ainda está em uso e é gerenciado pelo Time de Respostas a Emergências Computacionais da Força Aérea (AFCERT). Como normalmente ocorre, o grupo de desenvolvimento do projeto ASIM fundou uma empresa comercial em 1994, *Wheel Group*. O produto deles, *NetRanger*, foi o primeiro dispositivo de detecção de intrusão de rede comercialmente viável. Porém, SDIs comerciais se desenvolveram muito lentamente nesse período e só foram ganhar força no final da década.

O mercado de detecção de intrusão começou a ganhar popularidade e gerar retorno somente por volta de 1997. Nesse ano, a empresa líder na área de segurança, ISS, desenvolveu um sistema de detecção de intrusão de rede chamado RealSecure. Um ano depois, a Cisco reconheceu a importância desse mercado e comprou a *Wheel Group*, realizando uma solução de segurança que podia ser vendida aos clientes. Do mesmo modo, a *Centrax Corporation*, surgiu como um resultado da fusão da equipe de desenvolvimento do *Haystack Labs* e do time do CMDS da SAIC. A partir desse momento, os SDIs ampliaram sua faixa de mercado e têm gerado novas empresas, fusões e aquisições.

[Anterior](#) [Índice](#) [Próxima](#)

Copyright © 2003 Rafael P. Laufer